BASIC VULNERABILITY ASSESSMENT REPORT

Abstract:

This assignment documents a vulnerability assessment and basic exploitation workflow performed against a lab target (IP 192.168.188.129) running in VMware. The goal is to identify open services, enumerate vulnerabilities using automated scanners, and demonstrate (conceptually and practically) exploitation steps for selected critical findings. The report contains methodology, findings, proof-of-concept commands, remediation recommendations, and an appendix with raw scan output and Nessus plugin summaries.

Scope:

- Target: 192.168.188.129 (VMware guest)
- Subnet: 255.255.255.0 (/24)
- Attacking host: VMware workstation (same network)
- Tools allowed: Nmap (port/service discovery), Nessus (vulnerability scanning), Metasploit (exploit verification)
- Scope: Only the single target IP listed above. All actions performed within an isolated lab environment.

Methodology:

Reconnaissance

- Performed host discovery and port/service enumeration using Nmap.

Vulnerability Scanning

- Ran Nessus to identify known vulnerabilities and rank by severity.

Exploitation (Proof of Concept)

- Where safe and permitted, verified vulnerabilities using Metasploit modules (non-destructive, controlled exploitation).

Reporting & Remediation

- Compiled findings, recommended mitigations, and suggested follow-up actions.

Detailed Findings:

Metasploit Findings:

Important: All exploitation was performed in a controlled lab environment and limited to non-destructive verification where possible.

```
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:7b:98:85
          inet addr:192.168.188.129  Bcast:192.168.188.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fe7b:9885/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:1114 errors:0 dropped:0 overruns:0 frame:0
          TX packets:1094 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:68828 (67.2 KB)  TX bytes:65167 (63.6 KB)
          Interrupt:17 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:151 errors:0 dropped:0 overruns:0 frame:0
          TX packets:151 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:46609 (45.5 KB)  TX bytes:46609 (45.5 KB)
```

Nmap Findings:

Nmap scan report for 192.168.188.129

Host is up (0.0025s latency).

Not shown: 977 closed tcp ports (reset)

PORT STATE SERVICE

21/tcp open ftp

22/tcp open ssh

23/tcp open telnet

25/tcp open smtp

53/tcp open domain

80/tcp open http

111/tcp open rpcbind

139/tcp open netbios-ssn

445/tcp open microsoft-ds

512/tcp open exec

513/tcp open login

514/tcp open shell

1099/tcp open rmiregistry

1524/tcp open ingreslock

2049/tcp open nfs

2121/tcp open ccproxy-ftp

3306/tcp open mysql

5432/tcp open postgresql

5900/tcp open vnc

6000/tcp open X11

6667/tcp open irc

8009/tcp open ajp13

8180/tcp open unknown

MAC Address: 00:0C:29:7B:98:85 (VMware)

Nessus Findings:

Scan Details

Policy:	Basic Network Scan
Status:	Completed
Severity Base:	CVSS v3.0
Scanner:	Local Scanner
Start:	Today at 1:44 PM
End:	Today at 2:05 PM
Elapsed:	21 minutes

Vulnerabilities

Host	Auth	Vulnerabilities
192.168.188.129	Fail	11 7 26 9 137

Action	Vulns	Hosts
ISC BIND 9.x < 9.11.22, 9.12.x < 9.16.6, 9.17.x < 9.17.4 DoS: Upgrade to BIND 9.11.22, 9.16.6, 9.17.4 or later.	3	1
Samba Badlock Vulnerability: Upgrade to Samba version 4.2.11 / 4.3.8 / 4.4.2 or later.	1	1
UnrealIRCd Backdoor Detection: Re-download the software, verify it using the published MD5 / SHA1 checksums, and re-install it.	0	1

Summary:

Nessus reported multiple findings across severity levels. Critical items included backdoor/remote code execution vulnerabilities (e.g., UnrealIRCd backdoor, Canonical/Ubuntu critical issues), and default-account/remote-shell exposures. High-severity findings included service detection issues and rlogin-related weaknesses. Medium and low findings included weaker service configurations and outdated libraries.

Key points:

- Several critical findings had publicly available Metasploit modules or proof-of-concept exploits.
- Default accounts and exposed remote shells increase the risk of compromise.

(Selected Nessus plugin summaries and IDs are included in the Appendix.)

Overview of Risks Findings

Critical Risks:

1) **SSL Version 2 and 3 Protocol Detection**

Description

The remote service accepts connections encrypted using SSL 2.0 and/or SSL 3.0. These versions of SSL are affected by several cryptographic flaws, including:
- An insecure padding scheme with CBC ciphers.
- Insecure session renegotiation and resumption schemes.
An attacker can exploit these flaws to conduct man-in-the-middle attacks or to decrypt communications between the affected service and clients.
Although SSL/TLS has a secure means for choosing the highest supported version of the protocol (so that these versions will be used only if the client or server support nothing better), many web browsers implement this in an unsafe way that allows an attacker to downgrade a connection (such as in POODLE). Therefore, it is recommended that these protocols be disabled entirely.
NIST has determined that SSL 3.0 is no longer acceptable for secure communications. As of the date of enforcement found in PCI DSS v3.1, any version of SSL will not meet the PCI SSC's definition of 'strong cryptography'.

Solution

Consult the application's documentation to disable SSL 2.0 and 3.0.
Use TLS 1.2 (with approved cipher suites) or higher instead.

Plugin Details

Severity:Critical

ID:20007

Version:1.34

Type:remote

Family:Service detection

Published:October 12, 2005

Modified:April 4, 2022

Risk Information

Risk Factor: Critical

CVSS v3.0 Base Score: 9.8

CVSS v3.0 Vector:
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CVSS v2.0 Base Score: 10.0

CVSS v2.0 Vector:
CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

Vulnerability Information

In the news: true

2) **Bind Shell Backdoor Detection**

Description

A shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly.

Solution

Verify if the remote host has been compromised, and reinstall the system if necessary.

Plugin Details

Severity:Critical

ID:51988

Version:1.10

Type:remote

Family:Backdoors

Published:February 15, 2011

Modified:April 11, 2022

Risk Information

Risk Factor: Critical

CVSS v3.0 Base Score: 9.8

CVSS v3.0 Vector:
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CVSS v2.0 Base Score: 10.0

CVSS v2.0 Vector:
CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

3) **Debian OpenSSH/OpenSSL Package Random Number Generator**

Description

The remote SSH host key has been generated on a Debian or Ubuntu system which contains a bug in the random number generator of its OpenSSL library.
The problem is due to a Debian packager removing nearly all sources of entropy in the remote version of OpenSSL. An attacker can easily obtain the private part of the remote key and use this to set up decipher the remote session or set up a man in the middle attack.

Solution

Consider all cryptographic material generated on the remote host to be guessable. In particuliar, all SSH, SSL and OpenVPN key material should be re-generated.

Plugin Details

Severity:Critical

ID:32314

Version:1.21

Type:remote

Family:Gain a shell remotely

Published:May 14, 2008

Modified:July 24, 2024

VPR Key Drivers

Threat Recency: No recorded eventsThreat Intensity: Very LowExploit Code Maturity: FunctionalAge of Vuln: 730 days +Product Coverage: MediumCVSSV3 Impact Score: 3.6Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 5.1

Exploit Prediction Scoring System (EPSS): 0.0165

Risk Factor: Critical

CVSS v2.0 Base Score: 10.0

CVSS v2.0 Temporal Score: 8.3

CVSS v2.0 Vector:
CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C

CVSS v2.0 Temporal Vector:
CVSS2#E:F/RL:OF/RC:C

Vulnerability Information

Exploit Available: true

Exploit Ease: Exploits are available

In the news: true

Exploitable With

Core Impact

Reference Information

CWE: 310
BID: 29179
CVE: CVE-2008-0166

High Risks

1) **Samba Badlock Vulnerability**

Description

The version of Samba, a CIFS/SMB server for Linux and Unix, running on the remote host is affected by a flaw, known as Badlock, that exists in the Security Account Manager (SAM) and Local Security Authority (Domain

Policy) (LSAD) protocols due to improper authentication level negotiation over Remote Procedure Call (RPC) channels. A man-in-the-middle attacker who is able to able to intercept the traffic between a client and a server hosting a SAM database can exploit this flaw to force a downgrade of the authentication level, which allows the execution of arbitrary Samba network calls in the context of the intercepted user, such as viewing or modifying sensitive security data in the Active Directory (AD) database or disabling critical services.

Solution

Upgrade to Samba version 4.2.11 / 4.3.8 / 4.4.2 or later.

Plugin Details

Severity:High

ID:90509

Version:1.8

Type:remote

Family:General

Published:April 13, 2016

Modified:November 20, 2019

VPR Key Drivers

Threat Recency: No recorded eventsThreat Intensity: Very LowExploit Code Maturity: UnprovenAge of Vuln: 730 days +Product Coverage: MediumCVSSV3 Impact Score: 5.9Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 5.9

Exploit Prediction Scoring System (EPSS): 0.7865

Risk Factor: Medium

CVSS v3.0 Base Score: 7.5

CVSS v3.0 Vector:
CVSS:3.0/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:H

CVSS v3.0 Temporal Vector:
CVSS:3.0/E:U/RL:O/RC:C

CVSS v3.0 Temporal Score: 6.5

CVSS v2.0 Base Score: 6.8

CVSS v2.0 Temporal Score: 5.0

CVSS v2.0 Vector:
CVSS2#AV:N/AC:M/Au:N/C:P/I:P/A:P

CVSS v2.0 Temporal Vector:
CVSS2#E:U/RL:OF/RC:C

Vulnerability Information

CPE: cpe:/a:samba:samba

Exploit Available: false

Exploit Ease: No known exploits are available

Patch Pub Date: April 12, 2016

Vulnerability Pub Date: March 23, 2016

In the news: true

Reference Information

CERT: 813296
BID: 86002
CVE: CVE-2016-2118

2) **NFS Shares World Readable**

Description

The remote NFS server is exporting one or more shares without restricting access (based on hostname, IP, or IP range).

Solution

Place the appropriate restrictions on all NFS shares.

Plugin Details

Severity:High

ID:42256

Version:1.12

Type:remote

Family:RPC

Published:October 26, 2009

Modified:February 21, 2024

Risk Information

Risk Factor: Medium

CVSS v3.0 Base Score: 7.5

CVSS v3.0 Vector:
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

CVSS v2.0 Base Score: 5.0

CVSS v2.0 Vector:
CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N

Vulnerability Information

Vulnerability Pub Date: January 1, 1985

High Risks:

1) **SSL Anonymous Cipher Suites Supported**

Description

The remote host supports the use of anonymous SSL ciphers. While this enables an administrator to set up a service that encrypts traffic without having to generate and configure SSL certificates, it offers no way to verify the remote host's identity and renders the service vulnerable to a man-in-the-middle attack.
Note: This is considerably easier to exploit if the attacker is on the same physical network.

Solution

Reconfigure the affected application if possible to avoid use of weak ciphers.

Plugin Details

Severity:Medium

ID:31705

Version:1.31

Type:remote

Family:Service detection

Published:March 28, 2008

Modified:October 27, 2023

VPR Key Drivers

Threat Recency: No recorded eventsThreat Intensity: Very LowExploit Code Maturity: UnprovenAge of Vuln: 730 days +Product Coverage: LowCVSSV3 Impact Score: 3.6Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 4.4

Exploit Prediction Scoring System (EPSS): 0.027

Risk Factor: Low

CVSS v3.0 Base Score: 5.9

CVSS v3.0 Vector:
CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N

CVSS v3.0 Temporal Vector:
CVSS:3.0/E:U/RL:O/RC:C

CVSS v3.0 Temporal Score: 5.2

CVSS v2.0 Base Score: 2.6

CVSS v2.0 Temporal Score: 1.9

CVSS v2.0 Vector:
CVSS2#AV:N/AC:H/Au:N/C:P/I:N/A:N

CVSS v2.0 Temporal Vector:
CVSS2#E:U/RL:OF/RC:C

Vulnerability Information

CPE: cpe:/a:apache:tomcat

Exploit Available: false

Exploit Ease: No known exploits are available

Vulnerability Pub Date: May 9, 2007

Reference Information

BID: 28482
CVE: CVE-2007-1858

2) **SSL DROWN Attack Vulnerability (Decrypting RSA with Obsolete and Weakened eNcryption)**

Description

The remote host supports SSLv2 and therefore may be affected by a vulnerability that allows a cross-protocol Bleichenbacher padding oracle attack known as DROWN (Decrypting RSA with Obsolete and Weakened eNcryption). This vulnerability exists due to a flaw in the Secure Sockets Layer Version 2 (SSLv2) implementation, and it allows captured TLS traffic to be decrypted. A man-in-the-middle attacker can exploit this to decrypt the TLS connection by utilizing previously captured traffic and weak cryptography along with a series of specially crafted connections to an SSLv2 server that uses the same private key.

Solution

Disable SSLv2 and export grade cryptography cipher suites. Ensure that private keys are not used anywhere with server software that supports SSLv2 connections.

Plugin Details

Severity:Medium

ID:89058

Version:1.14

Type:remote

Family:Misc.

Published:March 1, 2016

Modified:April 4, 2025

VPR Key Drivers

Threat Recency: No recorded eventsThreat Intensity: Very LowExploit Code Maturity: UnprovenAge of Vuln: 730 days +Product Coverage: MediumCVSSV3 Impact Score: 3.6Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 3.6

Exploit Prediction Scoring System (EPSS): 0.9015

Risk Factor: Medium

CVSS v3.0 Base Score: 5.9

CVSS v3.0 Vector:
CVSS:3.0/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N

CVSS v3.0 Temporal Vector:
CVSS:3.0/E:U/RL:O/RC:C

CVSS v3.0 Temporal Score: 5.2

CVSS v2.0 Base Score: 4.3

CVSS v2.0 Temporal Score: 3.2

CVSS v2.0 Vector:
CVSS2#AV:N/AC:M/Au:N/C:P/I:N/A:N

CVSS v2.0 Temporal Vector:
CVSS2#E:U/RL:OF/RC:C

Vulnerability Information

Exploit Available: false

Exploit Ease: No known exploits are available

Patch Pub Date: March 1, 2016

Vulnerability Pub Date: March 1, 2016

In the news: true

Reference Information

CERT: 583776
BID: 83733
CVE: CVE-2016-0800

Low Risks:

1) **ICMP Timestamp Request Remote Date Disclosure**

Description

The remote host answers to an ICMP timestamp request. This allows an attacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols.

Timestamps returned from machines running Windows Vista / 7 / 2008 / 2008 R2 are deliberately incorrect, but usually within 1000 seconds of the actual system time.

Solution

Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14).

Plugin Details

Severity:Low

ID:10114

Version:1.56

Type:remote

Family:General

Published:August 1, 1999

Modified:October 7, 2024

VPR Key Drivers

Threat Recency: No recorded eventsThreat Intensity: Very LowExploit Code Maturity: PoCAge of Vuln: 730 days +Product Coverage: Very HighCVSSV3 Impact Score: 1.4Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 2.2

Exploit Prediction Scoring System (EPSS): 0.0037

Risk Factor: Low

CVSS v2.0 Base Score: 2.1

CVSS v2.0 Vector:
CVSS2#AV:L/AC:L/Au:N/C:P/I:N/A:N

Vulnerability Information

Vulnerability Pub Date: August 1, 1997

Reference Information

CWE: 200
CVE: CVE-1999-0524

2) **SSLv3 Padding Oracle On Downgraded Legacy Encryption Vulnerability (POODLE)**

Description

The remote host is affected by a man-in-the-middle (MitM) information disclosure vulnerability known as POODLE. The vulnerability is due to the way SSL 3.0 handles padding bytes when decrypting messages encrypted using block ciphers in cipher block chaining (CBC) mode.
MitM attackers can decrypt a selected byte of a cipher text in as few as 256 tries if they are able to force a victim application to repeatedly send the same data over newly created SSL 3.0 connections.
As long as a client and service both support SSLv3, a connection can be 'rolled back' to SSLv3, even if TLSv1 or newer is supported by the client and service.
The TLS Fallback SCSV mechanism prevents 'version rollback' attacks without impacting legacy clients; however, it can only protect connections when the client and service support the mechanism. Sites that cannot disable SSLv3 immediately should enable this mechanism.
This is a vulnerability in the SSLv3 specification, not in any particular SSL implementation. Disabling SSLv3 is the only way to completely mitigate the vulnerability.

Solution

Disable SSLv3.
Services that must support SSLv3 should enable the TLS Fallback SCSV mechanism until SSLv3 can be disabled.

Plugin Details

Severity:Low

ID:78479

Version:1.26

Type:remote

Family:General

Published:October 15, 2014

Modified:June 23, 2023

VPR Key Drivers

Threat Recency: No recorded eventsThreat Intensity: Very LowExploit Code Maturity: PoCAge of Vuln: 730 days +Product Coverage: Very HighCVSSV3 Impact Score: 1.4Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 5.1

Exploit Prediction Scoring System (EPSS): 0.9385

Risk Factor: Medium

CVSS v3.0 Base Score: 3.4

CVSS v3.0 Vector:
CVSS:3.0/AV:N/AC:H/PR:N/UI:R/S:C/C:L/I:N/A:N

CVSS v3.0 Temporal Vector:
CVSS:3.0/E:P/RL:O/RC:C

CVSS v3.0 Temporal Score: 3.1

CVSS v2.0 Base Score: 4.3

CVSS v2.0 Temporal Score: 3.4

CVSS v2.0 Vector:
CVSS2#AV:N/AC:M/Au:N/C:P/I:N/A:N

CVSS v2.0 Temporal Vector:
CVSS2#E:POC/RL:OF/RC:C

Vulnerability Information

Exploit Available: true

Exploit Ease: Exploits are available

Vulnerability Pub Date: October 14, 2014

In the news: true

Reference Information

CERT: 577193
BID: 70574
CVE: CVE-2014-3566

Risk Assessment & Impact

- Critical vulnerabilities allow remote code execution — immediate high risk to confidentiality, integrity, and availability.
- Several network services with default or weak configurations permit lateral movement or persistence.

Prioritization (recommended):

1. Patch or remove services with known remote code execution/backdoor vulnerabilities.
2. Disable or restrict remote services (telnet, rlogin, anonymous ftp) and enforce strong authentication.
3. Harden database services (MySQL, PostgreSQL) — restrict network exposure and enforce strong credentials.

Remediation Recommendations

- Apply vendor patches or update to supported versions for affected software (e.g., UnrealIRCd, OS packages).
- Disable insecure services (telnet, rlogin) and replace with secure alternatives (SSH with key-based auth).
- Change default credentials and enforce strong password policy.
- Implement network segmentation and firewall rules to limit exposure of critical services.
- Regularly run vulnerability scans and follow up on critical findings promptly.

Conclusion

The asssment clearly demonstrated how multiple layers of weaknesses—open ports, outdated services, default accounts, and known backdoors—can combine to expose a system to full compromise. By systematically applying reconnaissance, vulnerability scanning, and controlled exploitation, we confirmed that the target host is highly vulnerable and representative of real-world misconfigurations.

This exercise highlights the importance of proactive defense. Routine patching, timely vulnerability management, disabling insecure services, and enforcing strong authentication are not optional but foundational to network security. Beyond technical fixes, organizations should establish regular vulnerability assessments, continuous monitoring, and incident response planning to sustain resilience. Implementing these measures will transform the assessed environment from an easily exploitable target into a hardened system with reduced attack surface and improved overall security posture.